



ARKA HEALTH, INC.

BUSINESS ASSOCIATE AGREEMENT

Template for execution with Covered Entity customers — review by counsel before use

ARKA-LGL-001 · Version 1.0 · Template — Counsel Review Before Execution

Document No.	ARKA-LGL-001
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Template — Counsel Review Before Execution
Review Cycle	Annual, and upon amendment of 45 C.F.R. Parts 160–164

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

This Business Associate Agreement (this “**Agreement**”) is entered into as of _____, 20__ (the “**Effective Date**”), by and between [COVERED ENTITY LEGAL NAME], a [state and form of organization] (“**Covered Entity**”), and ARKA Health, Inc., a Delaware corporation (“**Business Associate**”), and is incorporated into and made a part of that certain [Master Services Agreement / Subscription Agreement] between the parties dated _____ (the “**Services Agreement**”). Covered Entity and Business Associate are each a “**Party**” and together the “**Parties**.”

RECITALS

WHEREAS, Covered Entity is a “covered entity” as defined at 45 C.F.R. § 160.103, or a business associate acting on behalf of a covered entity, and wishes to receive from Business Associate certain clinical decision-support and administrative-workflow software services described in the Services Agreement (the “**Services**”);

WHEREAS, in the course of providing the Services, Business Associate may create, receive, maintain, or transmit Protected Health Information for or on behalf of Covered Entity; and

WHEREAS, the Parties intend by this Agreement to satisfy the business associate contract requirements of 45 C.F.R. §§ 164.314(a) and 164.504(e) under the Health Insurance Portability and Accountability Act of 1996, as amended, including by the Health Information Technology for Economic and Clinical Health Act and the regulations promulgated thereunder (collectively, “**HIPAA**”);

NOW, THEREFORE, in consideration of the mutual promises contained herein and other good and valuable consideration, the receipt and sufficiency of which are hereby acknowledged, the Parties agree as follows:

ARTICLE 1 — DEFINITIONS

1.1 Capitalized terms used but not otherwise defined in this Agreement have the meanings assigned to them at 45 C.F.R. §§ 160.103 and 164.501, as amended from time to time, including “Breach,” “Data Aggregation,” “Designated Record Set,” “Disclosure,” “Electronic Protected Health Information” (“**ePHI**”), “Individual,” “Minimum Necessary,” “Required by Law,” “Secretary,” “Security Incident,” “Subcontractor,” “Unsecured Protected Health Information,” and “Use.”

1.2 “**Protected Health Information**” or “**PHI**” means Protected Health Information as defined at 45 C.F.R. § 160.103, limited to the information created, received, maintained, or transmitted by Business Associate for or on behalf of Covered Entity pursuant to the Services Agreement, and includes ePHI.

ARTICLE 2 — OBLIGATIONS OF BUSINESS ASSOCIATE

2.1 Limitation on Uses and Disclosures. Business Associate shall not Use or Disclose PHI other than as permitted or required by this Agreement or as Required by Law. Business Associate shall comply with the provisions of Subpart E of 45 C.F.R. Part 164 applicable to business associates, and, to the extent Business Associate is to carry out one or more of Covered Entity’s obligations under Subpart E, shall comply with the requirements of Subpart E that apply to Covered Entity in the performance of such obligation(s).

2.2 Safeguards. Business Associate shall implement and maintain administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of ePHI,

and shall comply with Subpart C of 45 C.F.R. Part 164 (the “**Security Rule**”) with respect to ePHI. Without limiting the foregoing, Business Associate shall encrypt ePHI at rest and in transit using then-current industry-standard cryptographic algorithms and shall enforce multi-factor authentication for all access to systems containing ePHI.

2.3 Minimum Necessary. Business Associate shall request, Use, and Disclose only the minimum amount of PHI necessary to accomplish the intended purpose, consistent with 45 C.F.R. § 164.502(b) and Covered Entity’s minimum-necessary policies as communicated to Business Associate in writing.

2.4 Reporting.

- (a) **Impermissible Uses and Disclosures.** Business Associate shall report to Covered Entity any Use or Disclosure of PHI not permitted by this Agreement of which Business Associate becomes aware, without unreasonable delay and in no event later than ten (10) business days after discovery.
- (b) **Security Incidents.** Business Associate shall report to Covered Entity any Security Incident of which it becomes aware on the same timeline; provided, however, that the Parties acknowledge and agree that this Section constitutes notice of, and no further reporting shall be required for, Unsuccessful Security Incidents, meaning pings and other broadcast attacks on firewalls, port scans, unsuccessful log-on attempts, denials of service, and similar events that do not result in unauthorized access to or acquisition, Use, or Disclosure of ePHI.
- (c) **Breaches of Unsecured PHI.** Business Associate shall notify Covered Entity of any Breach of Unsecured PHI without unreasonable delay and in no event later than ten (10) business days after discovery, as “discovery” is determined under 45 C.F.R. § 164.410(a)(2). Such notice shall include, to the extent known: the identification of each Individual whose Unsecured PHI has been or is reasonably believed to have been accessed, acquired, Used, or Disclosed; a description of the nature of the Breach, including the date of the Breach and the date of discovery; the types of PHI involved; the identity of any person who committed or received the impermissible Use or Disclosure; mitigation and corrective actions taken or proposed; and such other information as Covered Entity may reasonably request to satisfy 45 C.F.R. §§ 164.404–164.408. Business Associate shall supplement its notice as additional information becomes available and shall cooperate with Covered Entity’s risk assessment under 45 C.F.R. § 164.402(2).
- (d) **Costs.** If a Breach arises from Business Associate’s violation of this Agreement, Business Associate shall bear the reasonable, documented costs of legally required notifications and of credit-monitoring services that Covered Entity reasonably determines to offer affected Individuals, without limiting any other remedy available under the Services Agreement.

2.5 Subcontractors. Business Associate shall ensure, in accordance with 45 C.F.R. §§ 164.308(b)(2), 164.314(a)(2)(iii), and 164.502(e)(1)(ii), that any Subcontractor that creates, receives, maintains, or transmits PHI on behalf of Business Associate agrees in writing to restrictions and conditions at least as restrictive as those that apply to Business Associate under this Agreement, including the Security Rule obligations described in Section 2.2. Business Associate shall maintain a current list of such Subcontractors, shall provide the list to Covered Entity upon written request, and shall remain responsible for the acts and omissions of its Subcontractors with respect to PHI as if they were Business Associate’s own. Exhibit A enumerates the minimum flow-down terms.

2.6 Access. Within ten (10) business days of a written request by Covered Entity, Business Associate shall make available PHI maintained in a Designated Record Set to Covered Entity, or, as directed in writing by

Covered Entity, to the Individual or the Individual's designee, in the form and format required by 45 C.F.R. § 164.524, including, where the PHI is maintained electronically and the form is readily producible, in the electronic form and format requested.

2.7 Amendment. Within fifteen (15) business days of a written request by Covered Entity, Business Associate shall make any amendment(s) to PHI in a Designated Record Set as directed or agreed to by Covered Entity pursuant to 45 C.F.R. § 164.526, or shall provide the information necessary for Covered Entity to make such amendment(s).

2.8 Accounting of Disclosures. Business Associate shall document Disclosures of PHI, and information related thereto, as would be required for Covered Entity to respond to a request for an accounting under 45 C.F.R. § 164.528, and shall provide such documentation to Covered Entity within fifteen (15) business days of a written request. Business Associate shall retain such documentation for six (6) years from the date of each Disclosure.

2.9 Books and Records. Business Associate shall make its internal practices, books, and records relating to the Use and Disclosure of PHI received from, or created or received by Business Associate on behalf of, Covered Entity available to the Secretary for purposes of determining Covered Entity's and Business Associate's compliance with HIPAA. Nothing in this Section constitutes a waiver of any applicable privilege.

2.10 Mitigation. Business Associate shall mitigate, to the extent practicable, any harmful effect known to Business Associate of a Use or Disclosure of PHI by Business Associate or its Subcontractors in violation of this Agreement.

2.11 Prohibition on Sale; Marketing. Business Associate shall not directly or indirectly receive remuneration in exchange for PHI except as permitted by 45 C.F.R. § 164.502(a)(5)(ii), and shall not Use or Disclose PHI for marketing purposes except as permitted by HIPAA and authorized in writing by Covered Entity.

ARTICLE 3 — PERMITTED USES AND DISCLOSURES BY BUSINESS ASSOCIATE

3.1 Services. Except as otherwise limited by this Agreement, Business Associate may Use and Disclose PHI to perform the Services, provided that such Use or Disclosure would not violate Subpart E of 45 C.F.R. Part 164 if done by Covered Entity, except as permitted by Sections 3.2 through 3.4.

3.2 Management and Administration. Business Associate may Use PHI for the proper management and administration of Business Associate and to carry out the legal responsibilities of Business Associate, and may Disclose PHI for such purposes where the Disclosure is Required by Law or where Business Associate obtains reasonable assurances from the recipient, documented in writing, that the PHI will be held confidentially and Used or further Disclosed only as Required by Law or for the purposes for which it was disclosed, and that the recipient will notify Business Associate of any instances of which it is aware in which the confidentiality of the information has been breached.

3.3 Data Aggregation. Business Associate may Use PHI to provide Data Aggregation services relating to the Health Care Operations of Covered Entity as permitted by 45 C.F.R. § 164.504(e)(2)(i)(B).

3.4 De-Identification. ☐ *If checked*, Business Associate may de-identify PHI in accordance with 45 C.F.R. § 164.514(a)–(c), and may Use and Disclose such de-identified information for any lawful purpose, it being

acknowledged that de-identified information is no longer PHI. *If not checked, de-identification of Covered Entity's PHI is not permitted other than as necessary to perform the Services.*

ARTICLE 4 — OBLIGATIONS OF COVERED ENTITY

- (a) Covered Entity shall notify Business Associate of any limitation in Covered Entity's notice of privacy practices under 45 C.F.R. § 164.520, of any change in or revocation of an Individual's permission to Use or Disclose PHI, and of any restriction on Use or Disclosure agreed to under 45 C.F.R. § 164.522, in each case to the extent such limitation, change, revocation, or restriction may affect Business Associate's Use or Disclosure of PHI.
- (b) Covered Entity shall not request Business Associate to Use or Disclose PHI in any manner that would not be permissible under Subpart E of 45 C.F.R. Part 164 if done by Covered Entity, except as permitted under Article 3.
- (c) Covered Entity represents that it has obtained, and shall maintain, all consents, authorizations, and legal permissions required for Business Associate's receipt and processing of PHI as contemplated by the Services Agreement.

ARTICLE 5 — TERM AND TERMINATION

5.1 Term. This Agreement is effective as of the Effective Date and shall terminate upon the later of (a) termination or expiration of the Services Agreement and (b) the return or destruction of all PHI as provided in Section 5.3.

5.2 Termination for Cause. Upon a Party's knowledge of a material breach of this Agreement by the other Party, the non-breaching Party shall provide written notice specifying the breach and shall afford the breaching Party thirty (30) days to cure. If the breach is not cured within such period, or if cure is not possible, the non-breaching Party may terminate this Agreement and the Services Agreement upon written notice.

5.3 Effect of Termination. Upon termination of this Agreement for any reason, Business Associate shall, at Covered Entity's election, return or destroy all PHI in its possession or control, and shall certify such return or destruction in writing within sixty (60) days, retaining no copies; provided that, where return or destruction is infeasible (including where retention is required by law or where PHI is contained in archival backup media maintained under Business Associate's standard retention schedule), Business Associate shall extend the protections of this Agreement to such retained PHI, shall limit further Uses and Disclosures to those purposes that make return or destruction infeasible, and shall destroy such PHI promptly when retention ceases to be required. Destruction shall conform to the media-sanitization standards of NIST Special Publication 800-88.

ARTICLE 6 — MISCELLANEOUS

6.1 Regulatory References; Amendment. A reference in this Agreement to a section of HIPAA or its implementing regulations means the section as in effect or as amended. The Parties shall negotiate in good faith to amend this Agreement from time to time as necessary for the Parties to comply with HIPAA, and either Party may terminate the Services Agreement upon sixty (60) days' written notice if the other Party declines to enter into a legally required amendment.

6.2 Interpretation. Any ambiguity in this Agreement shall be resolved in favor of a meaning that permits compliance with HIPAA. In the event of an inconsistency between this Agreement and the Services Agreement with respect to PHI, this Agreement controls.

6.3 Ownership. As between the Parties, all right, title, and interest in and to the PHI is and shall remain with Covered Entity (or the relevant Individuals, as applicable). Business Associate acquires no rights in PHI except the limited rights of Use and Disclosure expressly set forth herein.

6.4 No Third-Party Beneficiaries. Nothing in this Agreement shall confer upon any person other than the Parties and their respective successors and permitted assigns any rights, remedies, obligations, or liabilities whatsoever.

6.5 Survival. The obligations of Business Associate under Sections 2.8, 2.9, 5.3, and this Article 6 shall survive termination of this Agreement.

6.6 Governing Law. This Agreement shall be governed by and construed in accordance with the laws governing the Services Agreement, without regard to conflict-of-laws principles, except to the extent preempted by federal law.

6.7 Notices. Notices under this Agreement shall be delivered in accordance with the notice provisions of the Services Agreement, with copies of privacy-related notices to Business Associate addressed to: Privacy Officer, ARKA Health, Inc., privacy@getarka.health.

6.8 Counterparts; Electronic Signature. This Agreement may be executed in counterparts, each of which is an original and all of which together constitute one instrument, and may be executed and delivered by electronic signature with the same force and effect as an original signature.

IN WITNESS WHEREOF, the Parties have executed this Agreement by their duly authorized representatives as of the Effective Date.

[COVERED ENTITY LEGAL NAME]

By: _____

Name: _____

Title: _____

Date: _____

ARKA HEALTH, INC.

By: _____

Name: _____

Title: _____

Date: _____

EXHIBIT A — SUBCONTRACTOR FLOW-DOWN REQUIREMENTS

Each written agreement between Business Associate and a Subcontractor that creates, receives, maintains, or transmits PHI on behalf of Business Associate shall, at a minimum:

1. restrict the Subcontractor's Uses and Disclosures of PHI to those permitted to Business Associate under this Agreement, and prohibit any further Disclosure;
2. require the Subcontractor to comply with Subpart C of 45 C.F.R. Part 164 with respect to ePHI, including encryption of ePHI at rest and in transit and multi-factor authentication;
3. require the Subcontractor to report Security Incidents, impermissible Uses and Disclosures, and Breaches of Unsecured PHI to Business Associate without unreasonable delay, and in no event later than five (5) business days after discovery;
4. require the Subcontractor to bind its own subcontractors to terms at least as restrictive, in accordance with 45 C.F.R. § 164.502(e)(1)(ii);
5. require the Subcontractor to make PHI available for access, amendment, and accounting as necessary for Business Associate to perform Sections 2.6 through 2.8 of this Agreement;
6. require the Subcontractor to make its practices, books, and records available to the Secretary in accordance with 45 C.F.R. § 164.504(e)(2)(ii)(I);
7. require return or destruction of PHI upon termination on terms consistent with Section 5.3 of this Agreement, including NIST SP 800-88 sanitization; and
8. permit termination of the subcontract by Business Associate upon the Subcontractor's uncured material breach of its privacy or security obligations.

Business Associate's current Subcontractors that may create, receive, maintain, or transmit PHI (e.g., cloud infrastructure and managed database providers) are listed in the subcontractor register maintained under ARKA-SEC-009 and are available to Covered Entity upon written request.